# Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-15 09:00 WIB

## Top 5 Highlights

- Palo Alto Networks warns of PAN-OS RCE flaw exploited in attacks
- Unit 42 Uncovers PEERSTITCH, a Stealthy FortiGate Implant
- Cisco make-me-root email bug exploited as a 0-day by unknown crims
- FTC seeks to shut down companies accused of defrauding sextortion victims
- Ivanti ICS Zero-Day Attacks Highlight Vendor Patching Hurdles

# Threat Intelligence (10)

## 01. North Korean hackers target Ukraine for war intelligence

North Korean state-sponsored hackers are conducting spear-phishing campaigns targeting Ukrainian government, policy, and academic circles to gather intelligence on the country's position in the Russia-Ukraine war.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.scworld.com/brief/north-korean-hackers-target-ukraine-for-war-intelligence

## 02. AI worms could spread across your smart devices, Anthropic warns

Researchers say small AI models could be capable of spreading across vulnerable smart devices within months.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.malwarebytes.com/blog/ai/2026/10/ai-worms-could-spread-across-your-smart-devices-anthropic-warns

## 03. ROMULUS Malware Server Leverages ClickFix to Deliver Multiple Payloads

Researchers at Forescout said the discovery shows how ClickFix is evolving from a delivery technique into full-blown cyber-criminal infrastructure

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.infosecurity-magazine.com/news/romulus-malware-clickfix-deliver/

## 04. Microsoft Disrupts Chinese-Language Phishing Market Behind 1B+ Messages

Backed by a federal court order, Microsoft and Health-ISAC seized domains powering YAM Store, CoGUI, and Iron Man. The post Microsoft Disrupts Chinese-Language Phishing Market Behind 1B+ Messages appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.securityweek.com/microsoft-disrupts-chinese-language-phishing-market-behind-1b-messages/

## 05. Hirudo Android malware replaces banking apps to evade security checks

A new Android malware called Hirudo steals bank account credentials by replacing legitimate banking apps with modified versions that disable security checks. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/hirudo-android-malware-replaces-banking-apps-to-evade-security-checks/

## 06. [+24h Old] Fake AI Tools Put US Companies at Risk: Inside Counterfeit Claude, ChatGPT, and Copilot

ANY.RUN researchers tracked fake AI tool campaigns that impersonate Claude, ChatGPT, GitHub Copilot, Gemini, and other AI brands to plant infostealers, take over browser sessions, and phish business accounts. Between April 15 and October 5, 2026, 1,258 public sandbox analyses were tied to these campaigns, and the USA was the second-largest source of submiss…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://any.run/cybersecurity-blog/fake-ai-tools-us-companies/

## 07. [+24h Old] Four-Byte Write and Timing Bug Let Researchers Run Code in Windows SmartScreen Enclave

Security researchers ran their own code inside a protected part of Windows that is meant to stay sealed off even when the rest of the computer is taken over. The protected area is a VBS enclave, an isolated slice of memory the operating system uses to guard secrets, and the one they broke into handles passwords for a Windows anti-phishing feature. The work…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://thehackernews.com/2026/10/four-byte-write-and-timing-bug-let.html

## 08. [+24h Old] ISC Stormcast For Wednesday, October 14th, 2026 https://isc.sans.edu/podcastdetail/10136, (Wed, Oct 14th)

ISC Stormcast For Wednesday, October 14th, 2026
https://isc.sans.edu/podcastdetail/10136, (Wed, Oct 14th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://isc.sans.edu/diary/rss/33424

### 09. [+24h Old] North Korea Phishes Ukrainians for War Intel

The Democratic People's Republic of Korea (DPRK) is trying to get insight into its own war effort in Ukraine, through simple reply-baiting phishing attacks.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.darkreading.com/cyberattacks-data-breaches/north-korea-phishes-ukrainians-war-intel

### 10. [+24h Old] Anthropic warns self-replicating AI could spread to your smart devices

Anthropic is warning that small AI models could soon be able to self-replicate across consumer IoT devices, from Android TV boxes to smart ovens, creating distributed botnets capable of running AI workloads without relying on data centers. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/anthropic-warns-self-replicating-ai-could-spread-to-your-smart-devices/

## Latest Vulnerabilities (10)

### 01. Palo Alto Networks warns of PAN-OS RCE flaw exploited in attacks

Palo Alto Networks has released security updates for a high-severity PAN-OS RCE zero-day, tracked as CVE-2026-0322, that has been exploited in attacks targeting firewalls. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/palo-alto-networks-warns-of-pan-os-rce-flaw-exploited-in-attacks/

### 02. Unit 42 Uncovers PEERSTITCH, a Stealthy FortiGate Implant

We investigated an intrusion where attackers exploited CVE-2024-47575 to target 500+ firewalls and deploy PEERSTITCH, a memory-resident ARM64 malware. The post Unit 42 Uncovers PEERSTITCH, a Stealthy FortiGate Implant appeared first on Unit 42 .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://unit42.paloaltonetworks.com/fortimanager-cve-2024-47575-peerstitch-malware/

## 03. Cisco make-me-root email bug exploited as a 0-day by unknown crims

Both Switchzilla and CISA sound the alarm

Why it matters: Publicly discussed 0-days often see rapid weaponization, increasing the risk of opportunistic attacks at scale.

Recommendation: Apply vendor guidance immediately, reduce attack surface, and monitor for IoCs/exploitation telemetry until patches are fully deployed.

Sources: https://www.theregister.com/security/2026/10/14/cisco-make-me-root-email-bug-exploited-as-a-0-day-by-unknown-crims/5303168

## 04. Ivanti ICS Zero-Day Attacks Highlight Vendor Patching Hurdles

CVE-2026-104935, a high-severity authentication bypass + RCE vulnerability, was only partially discovered and patched in July, leaving an opening for threat actors to capitalize on.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/vulnerabilities-threats/ivanti-ics-zero-day-attacks-vendor-patching

## 05. Critical Ghostscript vulnerability allows remote code execution

A critical heap buffer overflow vulnerability in the Ghostscript interpreter, identified as CVE-2026-39919, could permit remote code execution through specially crafted PDF files.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/critical-ghostscript-vulnerability-allows-remote-code-execution

## 06. Akira ransomware attack highlights MFA gaps in VPN and RDP access

An Akira ransomware affiliate exploited a SonicWall SSL VPN vulnerability on Aug. 4, 2026, by spraying passwords, demonstrating a common security gap where organizations implement multi-factor authentication (MFA) for cloud services but leave other access points vulnerable.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/akira-ransomware-attack-highlights-mfa-gaps-in-vpn-and-rdp-access

## 07. SAP addresses 20 security flaws, including critical Python SDK vulnerability

SAP has released its October security updates, patching 20 vulnerabilities across its product suite. Among these is a maximum-severity flaw in the SAP Cloud SDK for Python, which could allow attackers to steal credentials.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/sap-addresses-20-security-flaws-including-critical-python-sdk-vulnerability

## 08. Docker Hub critical vulnerability allowed token misuse

Docker has disclosed a critical vulnerability in Docker Hub, identified as CVE-2026-105445, which could have allowed attackers to access other users' container repositories using a personal access token (PAT).

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/docker-hub-critical-vulnerability-allowed-token-misuse

## 09. Penetration testing every deployment with AWS Continuum

Most security tooling that fits into a CI/CD pipeline-static analysis (SAST), software composition analysis (SCA), and dynamic scanners (DAST)-flags potential issues from patterns and signatures. A flagged pattern shows you where to look; penetration testing is what confirms whether something is actually exploitable. That confirmation has traditionally come…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://aws.amazon.com/blogs/security/penetration-testing-every-deployment-with-aws-continuum/

## 10. Security researchers spent 6 days doing their Chromework, built 1B user exploit

Xbow earned a $250K bug bounty and all the AI model got was a lousy t-shirt

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/security/2026/10/14/security-researchers-spent-6-days-doing-their-chromework-built-1b-user-exploit/5303134

# Data Breach & Cybercrime (10)

## 01. FTC seeks to shut down companies accused of defrauding sextortion victims

The Federal Trade Commission is pursuing legal action to halt the operations of multiple digital security and privacy companies, alleging they have systematically defrauded customers out of millions of dollars through deceptive practices.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/ftc-seeks-to-shut-down-companies-accused-of-defrauding-sextortion-victims

## 02. Ransomware actors reportedly escalating to physical threats and violence

A recent survey suggests ransomware actors are increasingly threatening victims with physical violence, with a significant portion of respondents claiming these threats have been carried out.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.scworld.com/brief/ransomware-actors-reportedly-escalating-to-physical-threats-and-violence

## 03. Yam Store: The Phishing Network Behind a Billion Messages

A sprawling cybercrime marketplace supplied cloud infrastructure and phishing kits that helped fuel more than 1 billion phishing messages worldwide.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/cyberattacks-data-breaches/yam-store-phishing-network-behind-billion-messages

## 04. FBI raids DPRK IT worker laptop farms in Texas, US nationals arrested

The U.S. Department of Justice (DoJ) has disrupted the Famous Chollima threat group's operations by arresting two suspects, charging 14 individuals, and seizing nearly 187 laptops used in North Korean remote IT worker schemes. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/fbi-raids-dprk-it-worker-laptop-farms-in-texas-us-nationals-arrested/

## 05. Microsoft Disrupts 3 Phishing Kits Linked to Over 1 Billion Scam Messages

Microsoft and Health-ISAC, along with the Japan Cybercrime Control Center (JC3) and a coalition of private sector companies, such as Resecurity, Cloudflare, Oracle, Proofpoint, and TRM Labs, announced the disruption of three phishing kits, CoGUI (aka NX or FA), Haozi (aka Phoenix), and Iron Man System. "Since January 2026, the threat actors behind these kit...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/microsoft-disrupts-3-phishing-kits.html

## 06. U.S. Shuts Down Over 40 Laptop Farms, Charges 14 in North Korean IT Worker Fraud

The U.S. Department of Justice (DoJ) on Tuesday charged 14 people and seized about 187 computers as part of its ongoing efforts to disrupt North Korea's fraudulent remote IT worker (ITW) scheme. The indictment charges a mix of U.S. citizens and Chinese nationals for their roles in an IT worker conspiracy affecting more than 70 U.S. companies, charging them...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/us-shuts-down-over-40-laptop-farms.html

## 07. U.K. Sanctions Cryptomus for RU Money Laundering

The United Kingdom has issued economic sanctions against Cryptomus, a chameleonic cryptocurrency platform that experts say serves as a major conduit for payments related to ransomware, narcotics, darknet markets, fraud and cybercrime services that are helping Russia circumvent existing financial restrictions.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://krebsonsecurity.com/2026/10/u-k-sanctions-cryptomus-for-ru-money-laundering/

## 08. The Blind Spots of Agentic Pentesting and How to Close Them

AI-powered penetration testing can uncover complex attack paths, but safety restrictions and network limitations leave many assets and vulnerabilities untested. Picus Security explains how combining agentic pentesting with exposure validation and breach simulation can help close these gaps. […]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/the-blind-spots-of-agentic-pentesting-and-how-to-close-them/

## 09. FBI raids 40+ laptop farms helping North Korea pocket US tech salaries

North Korean IT workers used stolen and fabricated identities to land remote jobs at more than 70 US companies, with help from Americans who allegedly kept company-issued laptops running from their homes, according to the US Department of Justice. Arrests in Ohio, raids in Texas Michael James Bostelle of Pennsylvania and Juan Cecilio Pena Carrillo of Texas…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/10/14/north-korean-it-workers-laptop-farms-arrests/

## 10. How to Run a Deepfake Readiness Drill Before a Cloned Voice Calls Your Team

Cloned voices and synthetic video calls now show up in payment fraud, help desk resets, and access requests. A structured drill shows security teams exactly where verification breaks down, while nothing is at stake. The call comes in at 4:40 on a Friday. It's the CFO, or it sounds exactly like her, asking the controller to push a supplier payment out before…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/how-to-run-deepfake-readiness-drill.html